ACME Persistent DNS Challenge

draft-ietf-acme-dns-persist

A long-lived DNS TXT record, carrying a hashed `accounturi` and an optional `persistUntil` expiry, authorizes one CA account to issue for a domain or IP address with no DNS change at each issuance.

Shiloh Heurich (Fastly)
Henry Birge-Lee (Crosslayer Labs)
Michael Slaughter (Amazon Trust Services)

IETF 127 ACME WG — San Francisco

Since IETF 126 (Vienna)

Published in `-02` (Sept 2026)

- **Mandatory hashed `accounturi`**: `H(len || domain_name || key || account_URL)` under `accountHashPrefix` (#64)
- **Domain-omitted `*` opt-out**: client MAY / CA MUST
- **Rollover durability**: CAs retain witnessed account-key thumbprints for account lifetime; account deactivation overrides retention (#69)
- **`persistUntil` clamp**: clamps authorization `expires`
- **Directory `issuerDomainNames`**: pre-order discovery (#60)

Merged to `main` Post-`-02`

- ASCII-only hash canonicalization & IDN example fix: validated A-label input, ASCII lowercase + strip trailing dot; ASCII case-insensitive `issuer-domain-name` match
- Case-insensitive parameter names: `accounturi`, `policy`, `persistUntil`; duplicate recognized names rejected
- `accountHashPrefix` syntax: fits RFC 8659 TXT `value` grammar
- Validation flows & security limits + normative & JIT guidance + per-attempt cost

Subdomain Validation: `ancestorDomain` (#33)

Request-only selector (PR #84)

```
POST /chall/abc  →  { "ancestorDomain": "example.com" }
```

- **Three names:** cert identifier `F`, authz `identifier.value` `A` (`*.` stripped), record domain `R`
- Default `{}` sets `R = A` (including base wildcard `*.example.com`)
- Subdomain or deeper wildcard (`*.dept.example.com`) sends `"ancestorDomain": "example.com"`
- Challenge Object schema unchanged

Guardrails & RFC 9444

- **CA MUST recognize:** no silent fallback to `A`
- **Proper ancestor:** strict suffix of `A`; VDN ≤ 253 octets
- **Public suffixes rejected** (`unauthorized`) unless permitted by policy
- **Requires `policy=wildcard`** at `R`; digest hashes `R` (or `*`)
- **First accepted POST locks `R`** for the attempt
- **RFC 9444 (`subdomainAuthAllowed`):** coexists; satisfies only `A`

Ask: Any objection to `ancestorDomain` and RFC 9444 coexistence (PR #84)?

IP Validation: `_ip-validation-persist` (#32)

Additive profile for ACME `ip` identifiers (RFC 8738) in the reverse DNS tree (PR #85):

```
_ip-validation-persist.1.2.0.192.in-addr.arpa. IN TXT "authority.example; accounturi=https://ca.example/account-hash/sha-256/CnwSwHOHJbE-..."
```

- **Normalized Reverse Zone Domain Name (`R`):** lowercase `.in-addr.arpa` (4 reversed octets) or `.ip6.arpa` (32 reversed hex nibbles, 72 octets)
- **Distinct node name:** `_ip-validation-persist.<R>` (IANA Node Names + ACME Validation Methods `ip` registrations; no `PTR` indirection)
- **Digest `domain_name` input:** normalized `R` (or `*`) prior to following any CNAME aliases — deterministic across RFC 2317 CNAME delegation
- **Exact-address scope:** single IP only (`policy=wildcard` ignored; `ancestorDomain` rejected with `malformed` ; caches typed by `ip` vs `dns`)

Ask: Any objection to merging the `_ip-validation-persist` profile (PR #85) into this draft?

`persistExpired` Error Type (#39 / PR #86)

Registers `urn:ietf:params:acme:error:persistExpired` (RFC 8555 §9.7.4):

Rule	Requirement
1. Privacy Gate (`MUST NOT`)	CA **MUST NOT** return `persistExpired` if any record at the queried name validates, or if no record at that name is otherwise qualifying for the CA and **live requesting account** and failed solely due to an expired `persistUntil` (order-independent across RRsets).
2. Diagnostic (`SHOULD` / `MAY`)	When eligible on a challenge attempt, CA **SHOULD** return `persistExpired`, and **MAY** return `unauthorized` for uniform disclosure.

- **Just-in-Time validation:** continues to fall back to a `pending` challenge
- **Clients:** check `persistUntil` locally before ordering; handle both `persistExpired` and `unauthorized`

Why this split: Actionable expiration diagnostics with zero cross-account or cross-CA expiration oracle.

Certificate-Key Attestation Conjunction (#76)

Why DNS parameters and CAA alone cannot express `dns-persist-01` **AND** `device-attest-01`:

- Authorization `challenges` (RFC 8555 §7.1.4) and CAA `validationmethods` (RFC 8657 §4) are **disjunctive (`OR`)**; unknown TXT parameters are `MUST ignore`

Order-level conjunctive policy (PR #87)

1. **Non-waivable Order `authorizations` (RFC 8555 §7.1.3):** CA **MUST** include the attestation authorization on every Order in scope (covering wildcard/subordinate names) and **MUST NOT** allow client waiver
2. **CSR key binding at finalization (RFC 8555 §7.4):** CA **MUST** verify the CSR public key matches the Order's attested key — even across JIT or reused `dns` authorizations
3. **Key-rotation renewal:** JIT reuses `_validation-persist`; new Order requires fresh attestation for the rotated CSR key (`device-attest` cited informatively)

Ask: Any objection to specifying Order-level attestation conjunction in PR #87?

Mailing-List Implementation Feedback (Oct 13)

From Seo Suchan's Pebble `-02` implementation report:

1. Keep `https://` prefix

- **RFC 8657 §5.4:** `accounturi` URIs include an authority component
- **Zero directory savings:** pre-provisioning already uses directory `issuerDomainNames`
- **No BCP 35 hold:** avoids IANA scheme registration; aligned with servercert PR #9
- **Rebrands:** covered by §4.5 dual-acceptance migration

2. Keep inner `key` on SHA-256

```
H(len || domain_name || key || account_URL)
                            ^^^ 43-octet RFC 7638
```

- **Matches RFC 8555 §8.1:** reuses the exact `keyAuthorization` thumbprint clients and CAs already compute
- **One stored value per key:** CA retention table stores **one** 43-byte thumbprint per key regardless of outer `<hash-alg>`

Direction: Keep `https://` `accountHashPrefix` and fixed SHA-256 key input.

Implementation Status & Path to WGLC

Issue & PR Status

- **Merged to `main` (`fd52243`):**
  - #74, #75, #77–#83 (post-`-02` clarifications & `#69` cost notes)
- **Ready to Merge for `-03`:**
  - PR #84: `#33` `ancestorDomain` + RFC 9444
  - PR #85: `#32` `_ip-validation-persist`
  - PR #86: `#39` `persistExpired`
  - PR #87: `#76` `device-attest` conjunction
- **Zero unaddressed issues remain**

Implementations & CABF

- **Pebble:** merged (#536); `-02` fork tested
- **lego:** merged (#2871)
- **cert-manager:** design & prototype (#8373)
- **CAs:** Let's Encrypt, Fastly / Certainly, Amazon Trust Services, Google Trust Services
- **CA/B Forum:** draft ballot (servercert PR #9) aligned with `-03`

Release plan: Merge `#84` – `#87`, publish `-03`, and request **Working Group Last Call**.

Questions & Discussion

- Any objections to merging #84 (`ancestorDomain`), #85 (`_ip-validation-persist`), #86 (`persistExpired`), and #87 (attestation conjunction) into `-03`?
- Any objections to keeping `https://` `accountHashPrefix` and the fixed RFC 7638 SHA-256 inner thumbprint?
- Ready for **Working Group Last Call (WGLC)** once `-03` publishes?

Mailing list: acme@ietf.org

GitHub: open feature PRs #84–#87 · repository

Draft: https://datatracker.ietf.org/doc/draft-ietf-acme-dns-persist/